

Privacy Policy

LAST UPDATED: AUGUST 18, 2026

MĪZAN ("we", "us", "the service") is a personal finance dashboard that helps you view your bank accounts, brokerage holdings, transactions, and subscriptions in one place. This Privacy Policy explains what data we collect, how we use it, who we share it with, and the rights you have over your information.

1. Who we are

MĪZAN is operated by Amaan Khan as an individual operator (referred to throughout this policy as "we" or "the operator"). The service is hosted at <https://app.mizan.exchange>. For all privacy-related questions or data-subject requests, contact khanstyle02@gmail.com.

2. What data we collect

2.1 Account data you provide

- Your email address and password (hashed) when you sign up.
- Optional time-based one-time password (TOTP) factor if you enable multi-factor authentication.
- Optional preferences and settings you save inside the app.

2.2 Financial data via Plaid

When you link a bank or credit account through Plaid Link, Plaid returns the following to our backend on your behalf:

- An access token (stored server-side only, never sent to your browser).

- Account metadata: institution name, account name, masked number, type, subtype, current and available balances, currency.
- Recent transactions (merchant, amount, date, category). These **are stored** in our database so your spending history, budgets and recurring-payment detection survive between sessions.
- Recurring-transaction detection (subscriptions and recurring bills).

You authenticate directly with your financial institution inside Plaid Link. We never see your bank username or password.

2.3 Brokerage data via SnapTrade

When you connect a brokerage account through SnapTrade, SnapTrade returns a user-id and user-secret pair used to query holdings, balances, and trades on your behalf. Your brokerage credentials never touch our servers.

2.4 Market data

We query third-party market data providers (Polygon, Finnhub, Alpaca) for quotes and reference data using server-side credentials. These queries do not transmit any personally identifying information.

2.5 Technical data

We collect minimal technical data needed to operate the service securely: IP address, user-agent, timestamps of security-relevant actions (login, MFA changes, bank connect/disconnect, session revoke), and unhandled error events (via Sentry, with personally identifying information scrubbed).

2.6 Product usage counts

We keep a running count of how many times you open each part of the app (for example "Zakat" or "Screener"), so we can see which features are worth keeping and which are not. This is a **counter, not an activity log**: we store a number per section, not a timeline, so it cannot show when you used MĪZAN or in what order. It contains no financial information of any kind, and no IP address or device details.

3. How we use your data

- To display your accounts, balances, transactions, and holdings inside the MĪZAN dashboard.
- To calculate aggregated views (net worth, spending breakdown, recurring subscriptions, asset allocation).
- To authenticate you and secure your account.
- To detect anomalous activity such as authentication failure spikes or unusual sign-in locations.
- To send you transactional security alerts (e.g., new device, password change).
- To investigate and resolve service incidents.

We do **not** sell your personal data. We do not use your financial data for advertising, profiling, or any commercial purpose beyond operating the service you signed up for.

4. Who we share data with

We share data only with the third-party processors required to operate the service:

- **Vercel** — hosting and function execution.
- **Supabase** — database, authentication, row-level security.
- **Plaid** — bank aggregation. See [Plaid's End User Privacy Policy](#).
- **SnapTrade** — brokerage aggregation. See [SnapTrade's privacy notice](#).
- **Sentry** — error monitoring, with PII scrubbing.
- **Resend** — transactional and account email.
- **Anthropic** — powers the AI Assistant. When you send the Assistant a message, the relevant parts of your portfolio (such as holdings, cost basis and screening verdicts) are sent to Anthropic's API so it can answer about your own data. It is used to explain your information, never to make investment recommendations. If you never open the Assistant, nothing is sent. See [Anthropic's privacy policy](#).

We do not share your data with advertisers, data brokers, or any party not listed above. We may disclose data when required by law, court order, or to protect the rights, safety, and property of users, the operator, or the public.

5. How long we keep your data

- Account credentials, profile data, and connected-institution metadata are retained for as long as your MĪZAN account exists.
- Bank transactions retrieved through Plaid **are stored** in our database and kept for as long as the institution stays connected to your account. They are synced incrementally via `/transactions/sync` so that budgets, spending history and recurring-payment detection work across sessions.
- Product usage counts are kept for as long as your account exists and are deleted with it.
- Audit log entries are retained for at least 12 months for security and compliance review.
- If you disconnect an institution, we call Plaid's `/item/remove` endpoint to revoke our access token and delete the corresponding records from our database.
- If you delete your MĪZAN account, all of your data — including Plaid and SnapTrade rows — is cascade-deleted from our database.

6. Your rights

Depending on where you live, you may have rights under the GDPR, CCPA, or similar laws, including the right to:

- Access the personal data we hold about you.
- Correct inaccurate data.
- Delete your data ("right to erasure").
- Export your data in a portable format.
- Withdraw consent for further processing.

- Object to or restrict certain processing.
- Lodge a complaint with a supervisory authority.

To exercise any of these rights, email khanstyle02@gmail.com. We will respond within 30 days.

7. Security

We use industry-standard security practices, including:

- TLS 1.2 or higher for all data in transit.
- AES-256 encryption at rest for all stored data (Supabase).
- Row-Level Security policies so each user can only read their own data.
- Multi-factor authentication available to all users.
- Server-only storage of all access tokens and API secrets.
- Audit logging of every security-relevant action.
- Anomaly detection on authentication failures and provider errors.

For a more detailed description of our security practices, see our [SECURITY.md](#) in the project repository.

8. Children's privacy

MĪZAN is not intended for users under 18. We do not knowingly collect data from children. If you believe a child has provided us with personal data, contact us and we will delete it.

9. Changes to this policy

We may update this Privacy Policy. When we do, we update the "Last updated" date at the top of this page. Material changes will be communicated by email and via an in-app notice.

10. Contact

Questions, data requests, or complaints? Email khanstyle02@gmail.com.